

1.4 Restriction of Internet Access

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Control/Protect Internet access from operator PCs and systems within the secure zone. In-scope components: • dedicated and general-purpose operator PCs • jump server • messaging interface • communication interface • GUI • SwiftNet Link • Alliance Connect Virtual on Premises VPN • Swift and customer (client) connector • customer client connector • New HSM • bridging servers (such as middleware or file transfer servers other than customer connectors) used for and guardian of the secure data exchange between back-office and Swift-related components • [Advisory: on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform that hosts Swift-related VMs, including all the Alliance Connect Virtual VPN instances and their management PCs] Risk Drivers: • exposure to internet-based attacks						
<u>Implementation Guidance</u> Control Statement: All general-purpose and dedicated operator PCs, as well as systems within the secure zone, have controlled direct internet access in line with business¹⁷. Control Context: Direct access to the Internet raises exposure to internet-based attacks. Risk is even higher in case of human interactions (browsing, e-mails, or other social network activities being permitted). Once compromised, those systems can be an entry point that allows lateral movements or injection of command and control elements (or a combination of both). If reducing the attack surface and vulnerabilities of those systems (as per the relevant controls identified in this document) is primordial, then limiting and controlling direct Internet accesses is crucial. On top of (general) operator PCs that connect Swift-related services or applications offered by outsourcing agents, Swift (in the case of Alliance Lite2 or Alliance Cloud) or Swift connectivity providers, due diligence must be taken to secure (general) operator PCs used to access on-premises interfaces or GUIs. Insecurely combining access to the “production environment” and the Internet could be abused by attackers. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user’s						

¹⁷ Purpose is not to prohibit internet access but to limit/control connectivity where it is relevant for business related reasons (such as to access external service provider resources).

implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

a) Internet access from the secure zone

- General-purpose internet browsing (including e-mail activities) from systems within the Swift or customer secure zone is not permitted.
- Internet access from systems within the secure zone (for example, dedicated operator PCs or other Swift-related components) is highly restricted and ideally should be blocked.
 - When possible, activities that require the Internet are conducted outside of the secure zone. Example activities may include conducting daily business on swift.com, or downloading security updates for secure transfer into the secure zone.
 - If internet access is needed from within the secure zone, then access should be granted only to allowlisted URL destinations through a proxy with content inspection and adequate blocking or filtering controls. Connections are only permissible if they are initiated in the outbound direction.
- As the entry point into the secure zone, the jump server (located within the secure zone or another existing secure zone that has similar controls) does not have internet access.

b) Internet access from general-purpose operator PCs

- Control internet access provided on the general-purpose operator PCs used with the following purposes:
 - Connect to an application at the service provider (user-to-application) to process business transactions¹⁸.
 - Connect to a customer (client) connector
 - Access a messaging or communication interface through a browser-based GUI (for example, Alliance Web Platform or CREST WebGUI+).

Control access through one of the following options:

- internet access through a remote desktop or virtual machine solution
- internet access from the general-purpose operator PC to only allowlisted URL destinations through a proxy with content inspection, in combination with adequate blocking or filtering controls and permitting only outbound initiated connections
- internet access from the general-purpose operator PC through a Web Gateway (with content inspection, in combination with blocking or filtering controls) using maintained denylisted URL destinations
- Even if Swift strongly recommends controlling the internet access, another method to meet the control objective on those PCs accessing the user's Swift infrastructure is to enforce the use of a jump server that has no internet access combined with multi-factor authentication (in line with control 4.2) implemented on the individual Swift-related components/systems or at the jump server.

c) Internet access from other components (middleware servers or the virtualisation platform – Advisory)

- When used, internet access from the middleware server or the virtualisation platform underlying system (also referred to as the hypervisor) is highly restricted and ideally blocked.
 - When possible, activities that require the Internet are conducted from other systems. Examples of such activities include conducting daily business, or downloading security updates for secure transfer into the target system.
- If internet access is needed from those systems, then access should be granted only to allowlisted URL destinations through a proxy with content inspection and adequate blocking or filtering controls. Connections are only permissible if they are initiated in the outbound direction.

Optional Enhancement:

- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.

¹⁸ Such as, creating, submitting, approving or modifying business transactions or updating entitlements. Read-only/queries kind of access can be waived if entitlements cannot be changed from such operator PC's.